

QuantumShield — Week 2 Scope Lock

Project: QuantumShield

Track: Person A (Research & Design)

Date: 2026-09-20

Status: Locked for PoC

In Scope for Week 2–3 (MVP / Discovery Pillar)

- Source-code discovery scanner only.
- Detect usage of the following algorithms in a sample repository (Python and/or Java):
 - RSA
 - ECDSA
 - DH / ECDH
 - AES
 - MD5
- Convert findings into a schema-valid CycloneDX CBOM JSON (`cryptographic-asset` components).
- Capture basic detection context: file path + line number(s).
- Output a single `cbom.json` that validates against CycloneDX 1.6+ CBOM schema.

Out of Scope for this PoC

- Risk scoring engine / QRI calculation (Week 3+).
- Dashboard or UI.
- Container / image / filesystem scanning (cbomkit-theia's job).
- Full certificate, key, or protocol inventory beyond what the regex scanner can surface.
- Multi-language production-grade AST analysis.
- Dependency graph enrichment or `implements` vs `uses` resolution beyond a simple default.

Definition of Done (Week 2 PoC Success)

Scanner detects RSA / ECDSA / DH / AES / MD5 usage in a sample Python and/or Java repository and outputs a schema-valid `cbom.json`.

Acceptance checks: 1. `scanner.py` walks a target directory and applies patterns from `patterns.yaml`. 2. `cbom_writer.py` emits components of type `cryptographic-asset` with required `cryptoProperties`. 3. Generated file validates (ajv or equivalent) against CycloneDX 1.6+ schema. 4. At least one finding per target algorithm family appears with non-empty detection context.

This scope is intentionally narrow so Person B can deliver a working end-to-end PoC without scope creep.